MERROWFIELD DIGITAL

Past Incidents Casebook

Document Casebook 01 | Rev 2 | Effective 26 January 2026 | Owner: Security Operations | Review cycle: 12 months

1. How to read this casebook

These eight incidents were closed in 2024 and 2025, one of each attack type the desk handles. Each is summarised from its record: what happened, which reporting procedures applied and why, what the Data Protection Officer decided, and how the reporting went. They are told to show how the procedures work together, not to replace them: deadlines are read from the procedures themselves.

Case	Attack type	Procedures that applied	Decision
INC-BLR-0039464	Phishing and credential compromise	Procedure 01	NOTIFY REGULATOR AND CUSTOMERS
INC-WAW-0006894	Ransomware	Procedure 01 and Procedure 02	NOTIFY REGULATOR
INC-WAW-0029621	Other malware	None	RECORD ONLY
INC-BLR-0014682	Misdirected disclosure	Procedure 01	NOTIFY REGULATOR
INC-LIS-0021535	Lost or stolen device	None	RECORD ONLY
INC-BLR-0032907	Insider misuse	Procedure 01	NOTIFY REGULATOR AND CUSTOMERS
INC-TLL-0019432	Cloud misconfiguration	Procedure 01 and Procedure 03	NOTIFY REGULATOR
INC-LIS-0030387	Denial of service	Procedure 02	NOTIFY REGULATOR

2. Case 1 - Phishing and credential compromise

INC-BLR-0039464, Bengaluru hub. First alert 19:09 IST on 9 January 2025; confirmed 21:34 IST on 9 January 2025.

A third party told the desk that seller accounts were being taken over after a spoofed verification email. The analyst confirmed that the attacker had used a phished login on the seller portal and exported the records of 14,428 EU customers (14,607 records): contact details and account credentials, all in plaintext. Exfiltration was confirmed.

Procedure 01 applied: EU customers' data was involved, and the Data Protection Officer judged the risk to them high - credentials had been taken in plaintext. Plaintext data does not qualify for the exemption, so customers had to be told.

Decision: NOTIFY REGULATOR AND CUSTOMERS. The customer notice went out first - change your password, including anywhere else it was used, and remember that Merrowfield never asks for it by email - and the filing followed, stating when customers had been told.

3. Case 2 - Ransomware

INC-WAW-0006894, Warsaw hub. First alert 16:13 CEST on 26 July 2024; confirmed 16:48 CEST on 26 July 2024.

Ransomware encrypted 156 systems behind the order management database, and order processing was unavailable for 705 minutes. The database held the records of 335,969 EU customers (contact details) in plaintext. The attacker encrypted them; the investigation found no sign that any were taken.

Two procedures applied. Procedure 02, because the outage lasted more than 60 minutes and 335,969 customers were affected - more than one lakh; and Procedure 01, because EU customers' data was involved and the risk to them was judged medium. Nothing had been taken, so the risk was not judged high and customers were not told.

Decision: NOTIFY REGULATOR. The early warning reached the national CSIRT on the day, the notifications to both authorities followed within their deadlines, and the final report was filed a month after the incident notification.

4. Case 3 - Other malware

INC-WAW-0029621, Warsaw hub. First alert 16:58 CET on 4 January 2025; confirmed 23:38 CET on 4 January 2025.

An endpoint alert flagged a trojan on 5 employee workstations. The hosts were isolated and reimaged. The investigation confirmed that no personal data was on the machines or reachable from them, that no customer-facing service was affected, and that every affected system is hosted in the EU.

No procedure applied: no personal data, nothing significant, nothing in India.

Decision: RECORD ONLY. The incident was documented, as every incident is.

5. Case 4 - Misdirected disclosure

INC-BLR-0014682, Bengaluru hub. First alert 17:30 IST on 11 April 2025; confirmed 19:19 IST on 11 April 2025.

An agent emailed a file to the wrong recipient. It held the contact details of 484 EU customers (514 records) and nothing else - no credentials, no payment tokens. The recipient confirmed in writing that the file had been deleted.

Procedure 01 applied: EU customers' data was involved and the risk to them was judged medium. Contact details alone were not judged a high risk, so customers were not told.

Decision: NOTIFY REGULATOR.

6. Case 5 - Lost or stolen device

INC-LIS-0021535, Lisbon hub. First alert 15:05 WET on 2 January 2024; confirmed 16:55 WET on 2 January 2024.

A company laptop was stolen. It held a spreadsheet of 2,138 records for 1,507 EU customers: contact details and payment tokens. The disk was encrypted, and the recovery key was held centrally, not with the device.

The risk was judged low: data encrypted with a key that was not compromised is unintelligible to whoever has the laptop. Procedure 01 did not apply, because the band was LOW. Even had the risk been high, the Encrypted state would have excused telling customers.

Decision: RECORD ONLY. The device was wiped remotely at its next connection.

7. Case 6 - Insider misuse

INC-BLR-0032907, Bengaluru hub. First alert 23:12 IST on 1 August 2025; confirmed 12:49 IST on 2 August 2025.

A data loss prevention alert caught an analyst exporting 2,789 records of 2,499 EU customers from the analytics data warehouse to a personal cloud drive. The export used pseudonymised customer IDs, but the order details in it made people identifiable. Exfiltration was confirmed.

Procedure 01 applied, and the risk was judged high. Pseudonymised data does not qualify for the exemption: it can be linked back to a person.

Decision: NOTIFY REGULATOR AND CUSTOMERS. The account was suspended and evidence preserved under legal hold before anyone spoke to the employee.

8. Case 7 - Cloud misconfiguration

INC-TLL-0019432, Tallinn hub. First alert 11:38 EET on 2 January 2025; confirmed 14:36 EET on 2 January 2025.

A third party reported a publicly readable storage bucket belonging to backup storage hosted across the EU and India. It held 935 records for 402 EU customers and 277 customers in India: contact details and government ID, in plaintext. Access logs showed no downloads from outside the company.

Two procedures applied: Procedure 01, because EU customers' data was involved and the risk to them was judged medium, and Procedure 03, because the bucket was hosted partly in India and customers in India were affected.

The analyst worked to the sentence everyone remembers from Procedure 01: "The notification to the lead supervisory authority is due within 72 hours of awareness." Procedure 03 was not opened until the next morning. Its report was due six hours after the first alert; it reached CERT-In at 06:38 EET on 3 January 2025, 13 hours late. The notification to the lead supervisory authority was on time.

Decision: NOTIFY REGULATOR. The late report was itself recorded as a compliance failure. Its lesson is section 8 of Plan 01: read every applicable procedure, count each from its own start, and let the earliest deadline govern.

9. Case 8 - Denial of service

INC-LIS-0030387, Lisbon hub. First alert 07:31 WET on 1 January 2025; confirmed 08:14 WET on 1 January 2025.

A flood of traffic took the public website down for 173 minutes. An estimated 36,600 customers could not reach it, and the direct loss - lost orders and emergency capacity - was €88,948. No personal data was involved: a flood takes nothing.

Procedure 02 applied, because the outage lasted more than 60 minutes. Procedure 01 did not apply: no personal data was involved.

Decision: NOTIFY REGULATOR. The early warning, the incident notification and, a month after it, the final report all went to the national CSIRT within their deadlines.

10. What the cases teach

- Read every applicable procedure. The deadline everyone remembers is rarely the one that falls due first.
- Count each procedure from its own start: some count from awareness, one from the first alert.
- Encryption excuses telling customers only when the key was not compromised.
- Pseudonymised data is not unintelligible.
- An outage alone can make an incident significant, with no personal data at all.
- Every incident is documented, including the ones nobody is told about.